

Clase 282 — Políticas, estándares y procedimientos

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: (ISC)² CISSP Official Study Guide (Chapple, Stewart, Gibson)  Duración estimada: **90 min** · Nivel: **Intermedio**

Objetivo

Aprender a construir la jerarquía documental que sostiene un programa de seguridad: políticas, estándares, líneas base (baselines), directrices (guidelines) y procedimientos. Al terminar sabrás redactar una política clara y auditable, diferenciar cada tipo de documento, gestionar su ciclo de vida (aprobación, versión, revisión) y evitar el documento "de estantería" que nadie aplica.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

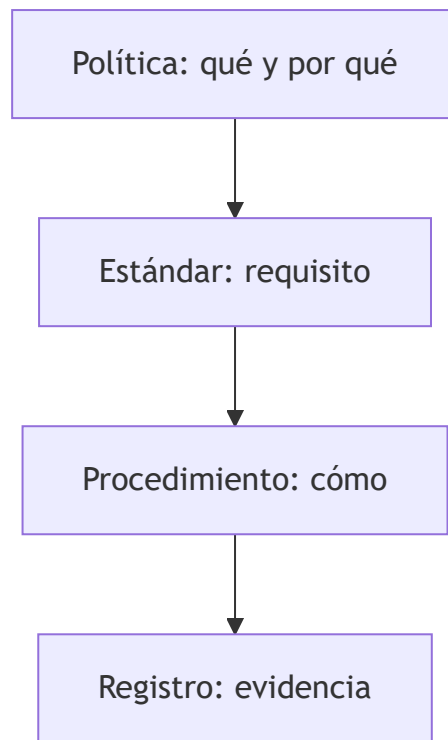
1. **Distinguir** política, estándar, baseline, directriz y procedimiento.
2. **Redactar** una política de seguridad completa y aplicable.
3. **Estructurar** un procedimiento paso a paso reproducible.
4. **Gestionar** el ciclo de vida documental (aprobación, versionado, revisión periódica).
5. **Vincular** cada documento a requisitos de negocio, riesgo o regulación.

Temas

#	Tema	Por qué importa
1	Jerarquía documental	Cada nivel tiene un propósito distinto
2	Políticas (obligatorias, de alto nivel)	Fijan la intención de la dirección
3	Estándares y baselines	Traducen la política a requisitos concretos
4	Directrices (recomendaciones)	Orientan sin obligar
5	Procedimientos (paso a paso)	Ejecución repetible
6	Ciclo de vida y control de versiones	Documentos vivos, no muertos
7	Excepciones y cumplimiento	Cómo gestionar desviaciones

Explicación en profundidad

La política expresa intención y autoridad; el estándar fija requisitos obligatorios; el procedimiento describe ejecución; la guía orienta. Mezclarlos produce documentos imposibles de mantener. Cada requisito necesita dueño, audiencia, excepción, evidencia y ciclo de revisión.



Caso razonado

Una política exige «parchear inmediatamente». Operaciones no puede medirla. Se crea estándar por riesgo y procedimiento de excepción; los registros permiten comprobar cumplimiento.

Glosario operativo

Término	Definición
Política	Mandato de alto nivel aprobado por autoridad.
Estándar	Requisito obligatorio y verificable.
Procedimiento	Secuencia operativa mantenida por un dueño.

Criterio de dominio

Hay dominio cuando el alumno convierte intención en requisito verificable, ejecución, excepción y registro coherentes.

Definiciones y características

- **Política:** declaración de alto nivel, obligatoria, aprobada por la dirección, que fija la intención y las reglas generales. *Clave:* dice el "qué" y el "por qué", no el "cómo".
- **Estándar:** requisito obligatorio y específico que da soporte a una política (p. ej. "AES-256 para datos en reposo"). *Clave:* medible y verificable.
- **Baseline (línea base):** nivel mínimo de seguridad para una categoría de sistema. *Clave:* configuración de partida obligatoria.
- **Directriz (guideline):** recomendación no obligatoria, buenas prácticas. *Clave:* "debería", no "debe".

- **Procedimiento:** instrucciones paso a paso para ejecutar una tarea. *Clave:* reproducible por cualquiera con el rol adecuado.
- **Excepción:** desviación aprobada y temporal de una política/estándar. *Clave:* se documenta, se aprueba y caduca.

Herramientas y preparación

- Editor Markdown o procesador de texto con control de cambios.
- Un sistema de versionado (Git, o el control de versiones de la wiki corporativa).
- Referencias de estructura: *SANS Security Policy Templates* y *NIST SP 800-12/800-100* como inspiración de forma (no copies contenido).
- Una plantilla de metadatos: título, versión, propietario, fecha de aprobación, próxima revisión, clasificación.

Laboratorio guiado (ejercicio aplicado)

Vas a redactar un conjunto documental coherente sobre **contraseñas y autenticación** para "Ferretería del Sur S.A.".

1. **Política** (1 nivel): redacta una *Política de Control de Acceso* de alto nivel (máx. 1 página) con: propósito, alcance, declaración de la dirección, roles, cumplimiento y sanciones. Añade metadatos (versión 1.0, propietario CISO, revisión anual).
2. **Estándar** (2 nivel): deriva un *Estándar de Autenticación* concreto: longitud mínima de contraseña, uso obligatorio de MFA, algoritmo de hash (bcrypt/Argon2), bloqueo tras N intentos. Cada requisito debe ser verificable.
3. **Baseline** (3 nivel): define la configuración mínima de autenticación para servidores Linux (p. ej. políticas PAM, `pwquality`, expiración) y para la aplicación web.
4. **Procedimiento** (4 nivel): escribe el procedimiento paso a paso "Alta y baja de una cuenta de usuario", numerado, con quién ejecuta, qué evidencia se guarda y verificación final.
5. **Directriz:** añade 3 recomendaciones no obligatorias (p. ej. usar gestor de contraseñas).
6. **Trazabilidad:** crea una tabla que vincule cada documento con el riesgo (acceso no autorizado) y la regulación (PCI Req.8, GDPR Art.32).
7. **Excepción de ejemplo:** redacta una solicitud de excepción temporal (un sistema legacy sin MFA) con justificación, compensación, aprobador y fecha de caducidad.

Ejercicios

1. Clasifica estas frases en política, estándar, baseline o procedimiento: "Usaremos MFA en todos los accesos"; "MFA mediante TOTP RFC 6238"; "Paso 3: escanear el QR con la app".
2. Reescribe una política mal redactada que mezcla "qué" y "cómo" separando niveles.
3. Diseña los metadatos mínimos que todo documento debe llevar.
4. Redacta un procedimiento de "restauración de un backup" en 6 pasos verificables.
5. Justifica por qué las directrices no deben ser obligatorias.
6. Diseña el flujo de aprobación y revisión anual de una política.

Reto verificable

Entrega un **paquete documental de control de acceso** con los cuatro niveles (política, estándar, baseline y procedimiento) coherentes entre sí, cada uno con metadatos completos, más una tabla de trazabilidad a riesgo y regulación y una solicitud de excepción de ejemplo.

Criterio de aceptación: la política no contiene detalles técnicos de "cómo" (esos van en estándar/procedimiento), cada estándar es verificable, el procedimiento es reproducible por un tercero, y todo documento tiene propietario y fecha de revisión.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Política de 20 páginas con detalles técnicos	Mezcla niveles; sube el "cómo" a estándar/procedimiento
Documentos sin propietario ni fecha de revisión	Quedan obsoletos; añade metadatos y ciclo de revisión
Nadie sigue el procedimiento	No es reproducible o no se comunicó; simplifica y forma
Excepciones permanentes	Contradicen la política; ponles caducidad y revisión
Estándar no verificable ("contraseñas seguras")	Vago; cuantifica (longitud, algoritmo, MFA)

Preguntas frecuentes

 **¿Cuál es la diferencia práctica entre estándar y directriz?** El estándar es obligatorio ("debe"); la directriz es recomendación ("debería"). Auditas el estándar, no la directriz.

 **¿Cada cuánto se revisan las políticas?** Al menos anualmente y ante cambios relevantes (nueva regulación, incidente, reorganización). La fecha de próxima revisión va en los metadatos.

 **¿Quién aprueba una política?** La dirección o el comité de seguridad; una política sin patrocinio de alto nivel carece de autoridad.

 **¿Puedo tener excepciones a una política?** Sí, si se documentan, se aprueban, tienen controles compensatorios y caducan. Una excepción permanente indica que la política necesita revisión.

Referencias

- (ISC)² CISSP Official Study Guide, dominio 1 (Documentación de seguridad).
- NIST SP 800-12 Rev.1 — An Introduction to Information Security.
<https://csrc.nist.gov/pubs/sp/800/12/r1/final>
- SANS Security Policy Templates. <https://www.sans.org/information-security-policy/>
- ISO/IEC 27001:2022, cláusula 5.2 (Política).
- ISO/IEC 27002:2022, control 5.1 (Políticas de seguridad de la información).



Material descargable

- [Guía en PDF](#) — versión imprimible de esta clase.
- [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 281 — Cumplimiento: GDPR, HIPAA y PCI-DSS](#)



Siguiente clase

[Clase 283 — Continuidad de negocio y plan de recuperación ante desastres](#)